Sumon Nath

Offensive Security Engineer | Penetration Testing (VAPT) Lead | Red Team Operator

Bengaluru, India · snath2973@gmail.com · +91 8360207436 · linkedin.com/in/gijutsu-hub · github.com/gijutsu-hub

PROFESSIONAL SUMMARY

Offensive security engineer with 3+ years delivering full-lifecycle Vulnerability Assessment and Penetration Testing (VAPT) and red team operations across 100+ engagements in banking and financial services (BFSI), fintech, e-commerce, government and enterprise environments. Hands-on across the MITRE ATT&CK kill chain, from reconnaissance and initial access through privilege escalation, lateral movement, defense evasion and exfiltration. Tests web, Application Programming Interface (API), mobile, thick-client and internal/external network targets with Common Vulnerability Scoring System (CVSS) 3.1 scoring and Common Weakness Enumeration (CWE) mapping. Also builds the defensive side: secure code review, Secure Software Development Lifecycle (SDLC) integration and cloud security posture management across Amazon Web Services (AWS) and Google Cloud Platform (GCP). Microsoft Most Valuable Security Researcher 2022 and 2023.

WORK EXPERIENCE

Senior Security Researcher, Team Lead

Alphawave Technology Pvt Ltd (Mitigata Security) | Bengaluru, India

Jan 2026 - Present

- Own end-to-end VAPT delivery for 100+ clients across web, REST/GraphQL/SOAP APIs, mobile (iOS and Android), internal and external network, Active Directory and firewall/perimeter assessments.
- Hold sole sign-off authority on all penetration test reports; manage report quality assurance, document control and the delivery pipeline while leading and mentoring a team of security interns.
- Execute adversary emulation aligned to MITRE ATT&CK: operate command-and-control (C2) infrastructure with redirectors and domain fronting, evade antivirus and Endpoint Detection and Response (EDR) through AMSI/ETW patching and reflective loading, then pivot via lateral movement, Kerberos abuse and credential harvesting to controlled exfiltration.
- Develop custom offensive tooling, payloads and loaders to extend coverage where commercial tooling is signatured or blocked.
- Produce audit-grade deliverables with CVSS 3.1 vectors, CWE classification and proof-of-concept exploitation chains mapped to SEBI CSCRF, CERT-In and ISO 27001 controls.
- Run Cloud Security Posture Management (CSPM) across AWS and GCP covering Identity and Access Management (IAM) privilege-escalation paths, storage exposure and CIS Benchmark review, plus Software Bill of Materials (SBOM) generation and Software Composition Analysis (SCA) for supply-chain risk.
- Engineer reconnaissance and attack-surface automation pipelines (Amass, httpx, nuclei) for continuous enumeration and vulnerability chaining, feeding ATT&CK-mapped telemetry into Sophos EDR security operations centre (SOC) dashboards.

Senior Software Engineer and Security Researcher

Loginsoft Pvt Ltd | Hyderabad, India

May 2024 - Nov 2025

- Reverse-engineered and reproduced disclosed Common Vulnerabilities and Exposures (CVEs) into working proof-of-concept exploits, deployed as deterministic test cases in instrumented sandbox environments.
- Built and integrated Static Application Security Testing (SAST) and SCA tooling (Checkmarx, Snyk), authoring custom query rules and sink/source definitions that reduced false positives and widened detection coverage.
- Embedded shift-left security gates into Continuous Integration/Continuous Deployment (CI/CD) pipelines, including automated scanning, dependency auditing and policy enforcement.
- Performed threat modeling, root-cause security debugging and vulnerability research across enterprise application stacks, alongside CIS-aligned server hardening.

Security Intern

Centre of Excellence in Cyber Security, VIT Bhopal | Bhopal, India

Jan 2023 - Feb 2024

- Designed and operated 20+ Capture The Flag (CTF) events in Jeopardy and Attack-Defense formats, authoring challenges in web exploitation, binary exploitation, reverse engineering, cryptography and forensics for 1000+ participants, sponsored by Offensive Security, Bugcrowd and HackerOne.
- Hardened campus infrastructure through firewall rule design, network segmentation using VLANs and access control lists, and deployment of enterprise security appliances.
- Supported vulnerability assessments and research on network security protocols and defensive architecture.

TECHNICAL SKILLS

Penetration Testing and Red Teaming: Vulnerability Assessment and Penetration Testing (VAPT), Web Application Penetration Testing, API Security Testing (REST, GraphQL, SOAP), Mobile Application Penetration Testing (iOS, Android), Network Penetration Testing, Active Directory Security, Red Team Operations, Adversary Emulation, MITRE ATT&CK, Command and Control (C2) Infrastructure, Privilege Escalation, Lateral Movement, EDR and Antivirus Evasion, Exploit Development, Thick Client Testing, Wireless Security

Application and Cloud Security: Secure Code Review, Static Application Security Testing (SAST), Dynamic Application Security Testing (DAST), Software Composition Analysis (SCA), Software Bill of Materials (SBOM), Threat Modeling (STRIDE), DevSecOps and CI/CD Security, Cloud Security Posture Management (CSPM), Amazon Web Services (AWS), Google Cloud Platform (GCP), IAM Security, Container Security

Detection and Response: Security Operations Centre (SOC), Endpoint Detection and Response (EDR), Detection Engineering, Threat Intelligence, Incident Response, Log Analysis, Purple Teaming

Frameworks and Standards: MITRE ATT&CK, OWASP Top 10, OWASP Application Security Verification Standard (ASVS), OWASP API Security Top 10, CVSS 3.1, CWE, NIST Cybersecurity Framework, ISO 27001, SEBI CSCRF, CERT-In, CIS Benchmarks, PTES

Tools: Burp Suite, Metasploit, Cobalt Strike, Nmap, Nessus, nuclei, Amass, httpx, MobSF, Checkmarx, Snyk, Wireshark, Sophos EDR, PyTorch, Ghidra

Programming Languages: Python, C, C++, Go, Rust, JavaScript, TypeScript, SQL, Bash, Node.js, React, Solidity

KEY PROJECTS

CtrlSec - AI-Powered Autonomous Security Operations Platform

ctrlsec.io

- Architected a full-stack autonomous threat-detection platform with a custom Large Language Model (LLM) driven threat-logic layer and an artificial intelligence compliance engine, designing backend services, inference pipeline and frontend console independently across Python, Node.js, React, Next.js and Go.
- Fused real-time threat-intelligence feeds, automated alert triage and correlation, and adversarial-simulation workflows into a unified SOC console.

AI-SAST Scanner - Deep-Learning Vulnerability Detection

- Engineered a deep-learning static analysis engine (Convolutional Neural Network with Bidirectional Long Short-Term Memory and Transformer attention, built in PyTorch) performing cross-function taint analysis across 35 vulnerability classes and 9 programming languages.
- Generated synthetic training corpora of 887,000 labeled entries and built an LLM-based supervision and validation framework; benchmarked against the OWASP Benchmark.

ACHIEVEMENTS AND RECOGNITION

- Microsoft Most Valuable Security Researcher (MVR), 2022 and 2023, for high-impact vulnerability submissions to Microsoft products.
- Five Common Vulnerabilities and Exposures (CVE) identifiers assigned for vulnerabilities discovered and reported through coordinated vendor disclosure, plus a contribution to a MITRE CWE weakness entry.
- Independent bug bounty researcher across 100+ programs, with valid vulnerabilities accepted by Microsoft, Google, Apple and NASA under Coordinated Vulnerability Disclosure.
- Organiser and challenge author for Damncon 2021 and 2022, a 24-hour Capture The Flag event rated 17.54 on CTFtime; challenge contributor to cyhunt and BSides.
- Invited speaker at security events for research contributions, including by Microsoft.

CERTIFICATIONS

- Certified Ethical Hacker (CEH) - EC-Council
- Offensive Security Certified Professional (OSCP) - In Progress

EDUCATION

Integrated Master of Technology (M.Tech), Computer Science and Engineering

Specialisation in Cybersecurity

Vellore Institute of Technology (VIT), Bhopal, India | 2020 - 2025